

REPORT DI ANALISI COMPORTAMENTALE

AVANZATA

STUDIO DINAMICO RANSOMWARE-WORM | EPICODE LAB

Analista Titolare:	Leandro Ancona	Data Esecuzione:	3 Giugno 2026
Campione Esaminato:	WannaCryptor.exe (WannaCry)	Ambiente d'Analisi:	Automated Cloud Sandbox
Metodologia:	Analisi Dinamica e Comportamentale	Istituto:	Epicode Institute of Technology

1. Metodologia d'Isolamento e Analisi in Sicurezza

L'analisi della minaccia ad alta proliferazione WannaCryptor.exe è stata condotta delegando l'esecuzione del binario a un ambiente di sandboxing isolato e controllato. Questo approccio ha consentito di intercettare a basso livello le chiamate di sistema (Syscalls), i processi figli e le relative comunicazioni di rete senza esporre a rischi crittografici l'infrastruttura host locale, garantendo la raccolta oggettiva di tutti i dati tecnici emersi a runtime.

2. Indicatori di Compromissione e Parametri di Identificazione

La fase preliminare di esecuzione ha permesso l'estrazione delle proprietà strutturali del file e l'attribuzione automatica del livello massimo di severità della minaccia.

LOG D'IDENTIFICAZIONE GENERALE DEL TARGET

Classificazione Minaccia: Score: 10/10 (Ransomware / Worm)

Nome File Rilevato: **WannaCry.exe**

Dimensione File System: 224 KB

Impronta Digitale SHA256:

be22645c61949ad6a077373a7d6cd85e3fae44315632f161adc4c99d5a8e6844

Tag Comportamentali Attivati: WANNACRY, RANSOMWARE, WORM, DEFENSE_EVASION, PERSISTENCE, EXECUTION, IMPACT.

3. Telemetria e Albero d'Esecuzione dei Processi

Il monitoraggio in tempo reale della catena dei processi generati ha registrato l'esatto comportamento operativo del payload a partire dall'attivazione dell'eseguibile principale.

TRACCIAMENTO SEQUENZIALE DELL'ATTIVITÀ DEI PROCESSI

- **Processo Padre:** **WannaCry.exe** (PID: 4588) localizzato nella directory temporanea dell'utente.
- **Invocazione Scripting:** Avvio di **cmd.exe /c 99801780499731.bat** (PID: 2416) seguito dall'esecuzione del sottoprocesso dell'interprete Windows Script Host **cscript //nologo c.vbs** (PID: 956).
- **Esecuzione Moduli di Ricatto:** Rilascio e attivazione dell'applicazione interattiva e persistente **!WannaDecryptor!.exe** (PID: 1672) operata con l'argomento flag **f** e successivamente con argomento **c** (PID: 4820).
- **Abbattimento dei Meccanismi di Ripristino (PID: 2524):** Invocazione dell'interprete dei comandi per la distruzione immediata dei backup e delle copie d'ombra locali tramite la stringa concatenata:
`cmd.exe /c vssadmin delete shadows /all /quiet & wmic shadowcopy delete & bcdedit /set {default} bootstatuspolicy ignoreallfailures & bcdedit /set {default} recoveryenabled no & wadmin delete catalog -quiet.`

4. Evasione delle Difese e Inibizione dei Servizi Locali

Al fine di aggirare il monitoraggio e garantire la disponibilità esclusiva dei file critici, il malware ha avviato un'attività forzata di terminazione dei servizi applicativi e dei server aziendali attivi nel sistema ospite.

REGISTRO DI INTERCETTAZIONE TASKKILL

L'utility di sistema **taskkill.exe** è stata richiamata ripetutamente con flag di terminazione forzata (**/f /im**) per neutralizzare i seguenti processi:

- **PID 4536:** `taskkill /f /im MExchange*` (Abbattimento dei server di posta elettronica).
- **PID 4624:** `taskkill /f /im Microsoft.Exchange.*` (Neutralizzazione servizi Exchange correlati).
- **PID 3528:** `taskkill /f /im sqlserver.exe` (Interruzione forzata del server database relazionale).
- **PID 3768:** `taskkill /f /im sqlwriter.exe` (Interruzione del servizio di scrittura SQL VSS).

5. Estrazione dei Dati della Ransom Note e Indicatori Finanziari

I moduli di monitoraggio hanno intercettato la configurazione interna del ransomware rilasciata all'interno del file di testo temporaneo **!Please Read Me!.txt** nella cartella `AppData\Local\Temp\`, consentendo l'acquisizione dei seguenti parametri d'attacco:

- **Estorsione Economica Richiesta:** Somma equivalente a **\$300 USD** da corrispondere tramite valuta crittografica Bitcoin.

- **Portafoglio Bitcoin di Destinazione (Wallet Address):**

15zGqZCTcys6eCjDkE3DypCjXi6QWRV6V1

- **Password di Decifratura dell'Archivio Risorse:** wcry123 (utilizzata internamente dal malware per scompattare i propri componenti operativi).

6. Conclusioni Tecniche e Considerazioni Profonde sul Malware

L'analisi dinamica avanzata condotta sui dati telemetrici estratti permette di formulare considerazioni approfondite di natura architetturale sulla minaccia WannaCry. Il binario esaminato non si configura come un ransomware convenzionale (il cui unico scopo è la cifratura asimmetrica dei file utente), bensì come un'arma informatica combinata a impatto infrastrutturale (Ransomware-Worm).

Dal punto di vista della **Defense Evasion**, la terminazione coordinata e chirurgica dei processi legati a Microsoft Exchange e SQL Server dimostra un elevato livello di pianificazione. Nei sistemi operativi Windows, i file dei database attivi sono protetti da un blocco di condivisione a livello di kernel che ne impedisce la lettura o la modifica da parte di processi terzi. Iniettando routine di `taskkill`, il malware rilascia forzatamente tali handle di memoria, consentendo la cifratura distruttiva dei record strutturati dell'azienda, che spesso rappresentano l'asset di maggior valore.

Parallelamente, l'azione distruttiva coordinata sul meccanismo di ripristino di Windows (tramite la combinazione di `vssadmin`, `wmic` e la riconfigurazione del boot database `bcdedit`) evidenzia la volontà di indurre la vittima in una condizione di totale impossibilità di ripristino autonomo. L'eliminazione del catalogo di Windows Backup (`wadmin delete catalog`) è l'evidenza definitiva di un attacco volto a massimizzare il tasso di conversione del riscatto finanziario.

In conclusione, questa attività di laboratorio evidenzia che la mitigazione di agenti di tale aggressività non può basarsi unicamente su soluzioni antivirus reattive (le quali intervengono quando il processo ha già avviato le violazioni di memoria), ma richiede una strategia di hardening proattiva. Questa deve includere la segmentazione rigida delle reti per bloccare il protocollo SMBv1 (vettore del modulo worm EternalBlue), l'implementazione di configurazioni di Least Privilege per impedire modifiche ai boot database e la centralizzazione dei backup in architetture immutabili e disconnesse dalla rete logica di dominio.